

## Chapter 2 – Phases of Ethical Hacking

---

### Introduction to the Phases of Ethical Hacking

Ethical hacking follows a structured process.

A hacker or penetration tester does not directly attack a system.

Instead, they follow multiple stages to:

- Gather information
  - Identify weaknesses
  - Exploit vulnerabilities
  - Maintain access
  - Remove traces
- 

### Main Phases of Ethical Hacking

| Phase                       | Purpose                                       |
|-----------------------------|-----------------------------------------------|
| <b>1</b> Reconnaissance     | Information Gathering                         |
| <b>2</b> Scanning           | Finding open ports, services, vulnerabilities |
| <b>3</b> Gaining Access     | Exploiting vulnerabilities                    |
| <b>4</b> Maintaining Access | Keeping persistent access                     |
| <b>5</b> Clearing Tracks    | Removing evidence/logs                        |

---

## **Reconnaissance (Information Gathering)**

### **Definition**

Reconnaissance means collecting information about the target before performing an attack.

This is the first and one of the most important phases of ethical hacking.

---

### **Goal of Reconnaissance**

The goal is to collect as much information as possible about the target.

Hackers gather information such as:

- Domain details
  - IP addresses
  - Email addresses
  - DNS records
  - Technologies used
  - Employee information
  - Phone numbers
  - Social media accounts
- 

### **Why Reconnaissance is Important?**

The more information an attacker collects:

- ✓ The easier it becomes to attack the target.

Cyber attacks mostly fail because of lack of information.

---

### **Daily Life Example**

Imagine a thief wants to rob a house.

Before entering:

- He checks security cameras
- Entry points
- Guard timings
- Lock system

This preparation is similar to reconnaissance in cybersecurity.

---

### Types of Reconnaissance

| Type                                                                                                     | Meaning                           |
|----------------------------------------------------------------------------------------------------------|-----------------------------------|
|  Passive Reconnaissance | No direct interaction with target |
|  Active Reconnaissance  | Direct interaction with target    |

---

### Passive Reconnaissance

#### Definition

Passive reconnaissance means gathering information without directly interacting with the target.

The target usually does not know they are being investigated.

---

### Information Gathered in Passive Recon

#### Domain Information

Attackers collect:

- Domain history
- Owner details
- Contact information
- Registrar details

This may reveal:

-  Email IDs

-  Phone numbers
  -  Public IP addresses
- 

### **DNS Information Gathering**

Attackers also gather DNS records such as:

#### **Record Type Purpose**

MX Record    Mail server information

NS Record    Name server details

A Record     Maps domain to IP

TXT Record   Verification/security info

---

### **Why Email IDs Are Important?**

Company email IDs help attackers perform:

- Phishing attacks
  - Password guessing
  - Social engineering
- 

### **Public IP Address**

A public IP address identifies the company/server on the internet.

Hackers use it for:

- Port scanning
  - Vulnerability detection
  - Service enumeration
-

## VirusTotal

### Definition

[VirusTotal](#) is an online malware analysis platform.

It allows users to scan:

- Files
- APKs
- URLs
- IP Addresses
- Hash Values

to check whether they are malicious or safe.

---

### Why VirusTotal is Used?

It helps identify:

- Malware
- Trojans
- Suspicious URLs
- Dangerous files

using multiple antivirus engines.

---

### Example

If you download an APK file from an unknown website:

Instead of directly installing it:

 Upload it to VirusTotal.

If many antivirus engines detect it:

 The file may contain malware.

---

### Important Cybersecurity Habit

**“Never trust unknown files directly.”**

Always verify before execution.

---

### Checking Where Gmail Login Was Used

Sometimes attackers investigate where a Gmail account is connected.

This helps understand:

- Which apps use the account
  - Which websites have login access
  - Third-party permissions
- 

### Steps to Check Google Account Connections

#### Method

**1** Open Google Account Security Settings

**2** Scroll to:

“Your connections to third-party apps & services”

**3** Click:

“See all connections”

You will see all apps/websites where “Sign in with Google” was used.

---

### Why This is Important?

If an attacker gains Gmail access:

They may access:

- Social media accounts
- Cloud storage
- Websites

- Banking notifications

because many accounts are linked to Gmail.

---

### **Saved Passwords in Browser**

Browsers can store saved login credentials.

Google provides:

### **Google Password Manager**

This stores:

- Website usernames
  - Passwords
  - Login details
- 

### **Security Risk**

If someone gains access to your browser or system:

They may view saved passwords.

---

### **Daily Life Example**

Saving passwords in browser is like:

 Writing all house keys inside a notebook and keeping it unlocked.

Convenient — but risky.

---

## Scanning Phase

### Definition

In the scanning phase, attackers scan the target system to identify:

- Open ports
- Running services
- Service versions
- Operating system details
- Vulnerabilities

---

### Goal of Scanning

The purpose is to identify weak points in the target system.

---

### What is a Port?

A port is a communication endpoint used by services.

---

### Common Ports

#### Port Service

80 HTTP

443 HTTPS

21 FTP

22 SSH

25 SMTP

---



## Why Open Ports Matter?

If a port is open:

It means some service is running there.

That service may contain vulnerabilities.

---

## Version Detection Concept

Suppose:

- Android 16 is latest
- Target device runs Android 11

Older versions may contain known vulnerabilities.

So attackers try to identify:

- OS version
  - Software version
  - Service version
- 

## Nmap Tool

### Definition

Nmap stands for:

### Network Mapper

It is one of the most popular scanning tools in cybersecurity.

---

## What Nmap Does?

Nmap helps identify:

- Live hosts
- Open ports
- Services

- Service versions
  - Operating systems
- 

### **Crafted Packets**

Nmap sends specially designed packets called:

### **Crafted Packets**

to the target machine.

The response helps determine system details.

---

### **TCP Handshake Example**

Suppose Machine A sends:

**SYN packet**

to Port 80 of Machine B.

If the port is open:

Machine B replies:

**SYN + ACK**

This indicates:

 Port is open.

---

### **Important Networking Concept**

TCP communication works using:

### **Three-Way Handshake**

#### **Step Packet**

- 1 SYN
- 2 SYN-ACK

## Step Packet

3 ACK

---

### Why Scanning is Important?

Scanning helps identify:

- Vulnerable services
- Old software
- Weak configurations

without directly exploiting the system yet.

---

### Vulnerability Databases

After identifying versions, attackers search vulnerability databases.

---

### Important Websites

#### CVE Database

[CVE Details](#)

Contains publicly known vulnerabilities.

---

#### NVD Database

[National Vulnerability Database \(NVD\)](#)

Provides detailed vulnerability analysis and severity ratings.

---

### Example

If scanning reveals:

- Apache version outdated

- Windows old build

Attackers search CVE database for known exploits.

---

### **Gaining Access**

#### **Definition**

After finding vulnerabilities, attackers exploit them to gain access to the target system.

This phase is called:

#### **Gaining Access**

---

#### **What is Exploitation?**

Exploitation means:

 **Taking advantage of a vulnerability.**

---

#### **Example**

If a website has SQL Injection vulnerability:

An attacker may bypass login and gain admin access.

---

#### **Remote Code Execution (RCE)**

#### **Definition**

RCE allows attackers to execute commands remotely on the victim system.

---

#### **Impact of RCE**

Attackers may:

- Install malware
- Delete files

- Spy on users
  - Create backdoors
  - Steal data
- 

## **Privilege Escalation**

### **Definition**

Privilege escalation means increasing access rights.

Example:

 Normal User →  Administrator

---

### **Why Attackers Need Admin Rights?**

Admin access allows:

- Full system control
  - Disabling antivirus
  - Installing malware
  - Accessing sensitive files
- 

## **Session Cookies**

### **Definition**

Session cookies store login session information.

When you select:

☒ “Keep me signed in”

the website creates a session cookie.

---

### **Chrome Session Cookie Location (Windows)**

The lecture mentioned:

%localappdata%\Google\Chrome\User Data\Default\Network

Cookies/session data may be stored within browser profile directories.

---

### **Cookie Hijacking Concept**

If an attacker steals and imports a valid session cookie:

They may access the victim's account without knowing the password.

This is called:

### **Session Hijacking / Cookie Hijacking**

---

### **Example**

Suppose:

- User already logged into Gmail
- Session timeout is long
- Attacker steals session cookie

If attacker imports that cookie:

 Browser may treat attacker as already authenticated.

---

### **Important Security Note**

Modern browsers and websites use security protections like:

- Encryption
- HttpOnly Cookies
- Secure Flags
- MFA
- Device Verification

to reduce such attacks.

Unauthorized access to accounts is illegal.

---

## **Clearing Tracks**

### **Definition**

After performing malicious activities, attackers may try to remove evidence.

This phase is called:

### **Clearing Tracks**

---

### **Goal**

To avoid detection by:

- System administrators
- Security teams
- Investigators

---

### **Temporary Files**

Attackers may remove temporary files from locations such as:

%temp%

or AppData directories.

---

### **Logs**

Operating systems and applications generate logs.

Logs record:

- Login activity
- Commands executed
- Errors

- File access
- 

### **Log Clearing**

Some attackers try to clear logs using commands/tools.

The lecture mentioned:

clear

or related shell commands.

However:

### **Important Point**

Even log deletion attempts may themselves generate new logs or alerts.

Security systems often detect suspicious log clearing activity.

---

### **Why Clearing Tracks Matters?**

Attackers want to:

- Hide identity
  - Avoid investigation
  - Remove forensic evidence
- 

### **Kali Linux**

#### **Definition**

[Kali Linux Official Website](https://www.kali.org/) is a Linux distribution specially designed for:

- Ethical hacking
  - Penetration testing
  - Digital forensics
  - Security research
-



## Features of Kali Linux

It comes pre-installed with tools such as:

- Nmap
- Wireshark
- Metasploit
- Burp Suite
- Aircrack-ng

---

## Virtual Machine (VM)

Kali Linux is often installed inside:

 **VMware**

or VirtualBox.

This allows safe practice without affecting the main operating system.

---

## Why Use Virtual Machines?

Benefits:

- ✓ Safe testing
- ✓ Isolation
- ✓ Snapshot recovery
- ✓ Easy installation
- ✓ Multiple OS support

---

## Daily Life Example

A virtual machine is like:

 Building a practice room inside your house without damaging the actual house.



## Quick Revision Table

| Topic                | Key Concept                         |
|----------------------|-------------------------------------|
| Reconnaissance       | Information gathering               |
| Passive Recon        | No direct interaction               |
| Scanning             | Find ports/services                 |
| Nmap                 | Network scanning tool               |
| CVE/NVD              | Vulnerability databases             |
| Exploitation         | Taking advantage of vulnerabilities |
| RCE                  | Remote command execution            |
| Privilege Escalation | User → Admin                        |
| Session Cookies      | Store login sessions                |
| Clearing Tracks      | Removing evidence                   |
| Kali Linux           | Ethical hacking OS                  |

## Chapter 2 Q & A

---

### 1. What are the Phases of Ethical Hacking?

#### Answer:

Ethical hacking follows a structured methodology to identify vulnerabilities in systems and networks. Ethical hackers do not directly attack systems randomly; instead, they follow specific stages to gather information, identify weaknesses, exploit vulnerabilities, and report findings.

---

#### Main Phases of Ethical Hacking

| Phase                                                                                                  | Purpose                     |
|--------------------------------------------------------------------------------------------------------|-----------------------------|
|  Reconnaissance       | Information gathering       |
|  Scanning           | Identifying ports/services  |
|  Gaining Access     | Exploiting vulnerabilities  |
|  Maintaining Access | Keeping persistence         |
|  Clearing Tracks    | Removing evidence           |
|  Reporting          | Documentation & remediation |

---

### 2. What is Reconnaissance in Ethical Hacking?

#### Answer:

Reconnaissance is the first phase of ethical hacking where attackers or penetration testers gather as much information as possible about the target.

The success of an attack heavily depends on the amount of information collected during reconnaissance.

---

## Information Collected During Reconnaissance

Attackers may collect:

-  Domain information
-  Email addresses
-  Public IP addresses
-  Employee details
-  Phone numbers
-  Organization details
-  Technologies used
-  DNS records
-  Social media accounts

---

## Real-Life Example

Before robbing a house, a thief studies:

- Security cameras
- Entry points
- Guard schedules
- Lock systems

Similarly, hackers study targets before attacking.

---

## 3. What are the Types of Reconnaissance?

### Answer:

Reconnaissance is divided into two major types:

| Type                                                                                                       | Meaning               |
|------------------------------------------------------------------------------------------------------------|-----------------------|
|  Passive Reconnaissance | No direct interaction |

**Type**

**Meaning**

- Active Reconnaissance Direct interaction
- 

● **4. What is Passive Reconnaissance?**

✓ **Answer:**

Passive reconnaissance involves gathering information without directly interacting with the target system.

The target usually does not know they are being investigated.

📁 **Examples of Passive Recon:**

- Google searching
- Social media research
- WHOIS lookup
- DNS information gathering
- Job posting analysis
- LinkedIn employee research

🎯 **Why Passive Recon is Important?**

Passive reconnaissance is stealthy because:

- ❌ No direct contact
  - ❌ Less chance of detection
  - ✓ Helps attackers build intelligence safely
-

## ● 5. What is Active Reconnaissance?

### ✓ Answer:

Active reconnaissance involves directly interacting with the target system to gather information.

This activity can often be detected by security systems.

---

### 📁 Examples:

- Port scanning
  - Vulnerability scanning
  - Sending emails
  - Network probing
  - Banner grabbing
- 

## 🌐 6. What is DNS Information Gathering?

### ✓ Answer:

DNS information gathering is the process of collecting DNS records related to a target domain.

These records reveal important infrastructure details.

---

### 📁 Common DNS Records

| Record     | Purpose                    |
|------------|----------------------------|
| A Record   | Maps domain to IP          |
| MX Record  | Mail server details        |
| NS Record  | Name server info           |
| TXT Record | Verification/security info |

---

 **7. Why are Company Email IDs Important to Attackers?**

 **Answer:**

Company email IDs are valuable because they help attackers perform:

-  Phishing attacks
  -  Password guessing
  -  Social engineering
  -  Malware delivery
- 

 **Example:**

If attackers know employee email formats like:  
john.doe@company.com

They can send realistic phishing emails pretending to be HR or IT support.

---

 **8. What is a Public IP Address?**

 **Answer:**

A public IP address identifies a device or server on the internet.

Hackers use public IPs for:

- Port scanning
  - Vulnerability detection
  - Service enumeration
  - Target identification
-

### 9. What is VirusTotal?

#### Answer:

VirusTotal is an online malware analysis platform used to scan:

- Files
- URLs
- APKs
- Hash values
- IP addresses

using multiple antivirus engines.

#### Purpose:

To identify whether a file or URL is malicious or suspicious.

---

#### Example:

Before installing software downloaded from an unknown website, security professionals upload it to VirusTotal to check whether antivirus engines detect malware.

---

### 10. Why Are Saved Browser Passwords Dangerous?

#### Answer:

Browsers can store usernames and passwords for convenience. However, if attackers gain access to the system or browser profile, they may steal saved credentials.

---

#### Risks:

- Account compromise
- Credential theft
- Unauthorized access



- Browser session hijacking

---

 **Example:**

Saved passwords are like keeping all house keys inside an unlocked drawer.  
Convenient but risky.

---

 **11. What is the Scanning Phase?**

 **Answer:**

The scanning phase involves analyzing the target system to identify:

- Open ports
  - Running services
  - Operating systems
  - Service versions
  - Vulnerabilities
- 

 **Goal of Scanning**

To identify weak points that may be exploitable.

---

 **12. What is a Port?** 

 **Answer:**

A port is a communication endpoint used by applications and services for network communication.

Different services use different ports.

---

## Common Ports

### Port Service

80 HTTP

443 HTTPS

21 FTP

22 SSH

25 SMTP

---

### Why Open Ports Matter?

Open ports indicate active services.

If those services are outdated or misconfigured, attackers may exploit them.

---

### 13. What is Nmap?

#### Answer:

Nmap (Network Mapper) is a powerful network scanning tool used for:

- Host discovery
- Port scanning
- Service detection
- OS detection
- Vulnerability identification

---

### How Nmap Works

Nmap sends specially crafted packets to the target system and analyzes the responses.

---

## Features of Nmap

- Detect live hosts
  - Detect open ports
  - Identify operating systems
  - Detect service versions
  - Security auditing
- 

## 14. Explain TCP Three-Way Handshake

### Answer:

TCP communication uses a process called the Three-Way Handshake to establish a connection.

---

### Steps

#### Step Packet

- 1 SYN
  - 2 SYN-ACK
  - 3 ACK
- 

### Working

- 1 Client sends SYN
- 2 Server responds with SYN-ACK
- 3 Client sends ACK

Connection becomes established.

---

 **15. What are CVE and NVD Databases?**

 **Answer:**

 **CVE**

CVE (Common Vulnerabilities and Exposures) is a public database containing known vulnerabilities.

 **NVD**

NVD (National Vulnerability Database) provides detailed analysis, severity ratings, and vulnerability information.

---

 **Example:**

If a server uses outdated Apache software, attackers search CVE databases for known exploits affecting that version.

---

 **16. What is Gaining Access?**

 **Answer:**

Gaining access is the phase where attackers exploit vulnerabilities to enter the target system.

---

 **Common Methods:**

- SQL Injection
  - Password attacks
  - Exploits
  - Remote Code Execution
  - Misconfigurations
-

## 17. What is Remote Code Execution (RCE)? 🔥

### ✅ Answer:

Remote Code Execution (RCE) is a vulnerability that allows attackers to execute commands remotely on a target machine.

---

### Impact of RCE

Attackers may:

- Install malware
  - Delete files
  - Create backdoors
  - Steal data
  - Control systems remotely
- 

## 18. What is Privilege Escalation?

### ✅ Answer:

Privilege escalation is the process of increasing access rights after gaining initial access.

Example:

 Normal User →  Administrator

---

### Why Attackers Want Admin Access

Admin privileges allow attackers to:

- Disable antivirus
- Access sensitive files
- Install malware
- Control the system fully

 **19. What are Session Cookies?**

 **Answer:**

Session cookies store authentication information after a user logs into a website.

These cookies help websites remember logged-in users.

---

 **Example:**

When users click:

 “Keep me signed in”

the browser stores session information.

---

 **20. What is Session Hijacking / Cookie Hijacking?**

 **Answer:**

Session hijacking occurs when attackers steal valid session cookies and use them to impersonate users.

The attacker may gain account access without knowing the password.

---

 **Security Protections**

Modern websites use:

- Secure cookies
- HttpOnly flags
- MFA
- Device verification
- Encryption

to reduce such attacks.

---

## 21. What is Clearing Tracks?

### Answer:

Clearing tracks is the phase where attackers attempt to remove evidence of their activities.

---

### Activities Include:

- Deleting logs
  - Removing temporary files
  - Clearing command history
  - Removing malware traces
- 

### Purpose

To avoid:

- Detection
  - Investigation
  - Digital forensics
- 

## 22. What is Kali Linux?

### Answer:

Kali Linux is a Linux distribution specially designed for:

- Ethical hacking
  - Penetration testing
  - Digital forensics
  - Security research
-

## Popular Tools in Kali Linux

- Nmap
  - Wireshark
  - Burp Suite
  - Metasploit
  - Aircrack-ng
- 

## 23. Why is Information Gathering So Important in Cybersecurity?

### Answer:

The more information attackers collect, the easier exploitation becomes.

Reconnaissance helps attackers:

- Understand the target
  - Identify weak points
  - Plan attacks effectively
  - Reduce chances of failure
- 

## 24. Difference Between Scanning and Reconnaissance

| Reconnaissance        | Scanning                |
|-----------------------|-------------------------|
| Information gathering | Technical analysis      |
| Mostly passive        | Mostly active           |
| Collects public info  | Detects vulnerabilities |
| Early phase           | Later phase             |

---